PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité Linux : Homologation, Durcissement et MCS

06-580 PSE 25-27 4-23 La Sécurité sous Linux - Homologation, Durcissement et Maintien en Conditions de Sécurité — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. L'homologation est une démarche décisionnelle où l'autorité compétente autorise la mise en service d'un système en acceptant les risques résiduels.
2. Le durcissement consiste à réduire un système au strict nécessaire en s'appuyant sur le moindre privilège et la réduction de la surface d'attaque.
3. Le maintien en conditions de sécurité assure la pérennité du niveau de sécurité via la surveillance, la gestion des vulnérabilités et la réévaluation régulière.

Introduction et contexte

Notion	À retenir
Pourquoi Linux	Environ **61 %** des serveurs web identifiés ; **open source** facilitant audit et durcissement. Menaces : vulnérabilités, erreurs de configuration, rançongiciels, chaîne de confiance.

L'homologation en sécurité

Notion	À retenir
Définition	Démarche aboutissant à une décision de l'**autorité compétente** pour autoriser la mise en service. Les risques **résiduels** sont acceptés car le **risque zéro** n'existe pas.
Cadre réglementaire	S'appuie sur le **RGS**, la **PSSIE**, la **PMSN**, l'**instruction 901**, les normes **ISO 27001/27005**, **EBIOS RM** et les **CIS Controls**.
Les acteurs	L'**AQSSI** (responsabilité juridique), l'**autorité d'homologation** (signe la décision), le **RSSI** (instruit/conseille), la **MOA** (besoin métier), la **MOE** (technique) et le **PASSI** (audit).
EBIOS Risk Manager	Méthode **ANSSI** en **5 ateliers** itératifs : **cadrage**, **sources de risque**, **scénarios stratégiques**, **scénarios opérationnels** et **traitement du risque**.
Processus d'homologation	7 étapes : **expression du besoin**, **analyse de risques**, **1er audit**, **mise en conformité**, **2nd audit** (audits : configuration, code, architecture, intrusion), **plan de remédiation** et **décision** (durée de **3 ans**).

Plan de remédiation

Notion	À retenir
Construction	**Repérer** les risques ; **classer** (urgent, planifié, compensé) ; action **corrective** ou **compensatoire** ; chaque action suivable (**qui**, **quand**, **comment vérifier**).

Synthèse du durcissement Linux

Notion	À retenir
Définition	Réduire le système via **4 leviers** (moindre privilège, réduction surface, contrôle accès, traçabilité) selon la **graduation ANSSI** (minimal, intermédiaire, renforcé, élevé).
Choix distribution	Privilégier le **support long terme**. Famille **RHEL/Rocky/AlmaLinux** (`SELinux`) vs famille **Debian/Ubuntu LTS** (`AppArmor`).
Comptes et PAM	Comptes **nominatifs**, orphelins désactivés (`passwd -l`, `nologin`), `visudo`. **PAM** (`/etc/pam.d/`, `pam_faillock.so`) appliqué par `sshd`, `sudo`.
Authentification et SSH	**MFA**, clés `ed25519`, **Fail2Ban** ; `PermitRootLogin no`, `PasswordAuthentication no`, `AllowUsers` ; tester `sshd -t` avant `reload`.
Permissions Linux	Modèle **rwx** (propriétaire, groupe, autres). Durcissement : `setfacl`, `umask 027`, **sticky bit** (`chmod +t /tmp`) et vigilance **SUID/SGID** (`find / -perm -4000`).
Gestion paquets	Réduire la surface d'attaque (moins de **CVE**). Pratiques : limiter (retirer compilateurs), authentifier (signatures), sourcer (dépôts confiance), tracer (CERT-FR).

Cas srv-app01 : durcissement SSH

Étape	Mesure
Situation initiale	SSH **root** direct, **mot de passe**, ouvert à **tout le réseau**, sans protection force brute.
Mesures	`PermitRootLogin no` ; clés `ed25519` + `PasswordAuthentication no` ; source limitée au réseau d'admin (`firewall-cmd --add-source=192.168.10.0/24`) ; **Fail2Ban**.
Vérification	`sshd -t`, `firewall-cmd --list-all`, `fail2ban-client status sshd`, `lastb`.

Synthèse de l'environnement de sécurité Linux

Notion	À retenir
Virtualisation et conteneurs	Hyperviseur : réseaux séparés, migrations chiffrées, correctifs. Conteneurs (noyau partagé) : images scannées, sans **root**, `SELinux` / `AppArmor`.
Réseau et stockage	**Segmenter** et filtrer les flux ; SAN/NAS segmentés et chiffrés, détection anti-rançongiciel.
Sauvegarde/Archivage	Dernier rempart. Appliquer la **règle 3 2 1** (3 copies, 2 supports, 1 externalisée). La fiabilité dépend de la **restauration testée**.
Cloud	Modèle de **responsabilité partagée** : le fournisseur sécurise l'infrastructure, le client est responsable de ses **données**, **accès** et **configurations**.
Annuaire/Authentification	Point de contrôle central. Pratiques : principe du **moindre privilège**, authentification **multifacteurs** pour l'administration et contrôle des groupes.
Outils de supervision	Leur compromission donne **visibilité** voire **contrôle** sur tout le SI : accès restreints, authentification forte, journaux centralisés, protection au niveau des systèmes supervisés.

Synthèse du MCS

Notion	À retenir
Définition	Activités pour conserver un niveau de sécurité conforme à l'**homologation**. Processus continu face aux menaces, vulnérabilités et usages.
La veille sécurité	Anticiper via **CERT-FR**, flux **CVE**, **threat intelligence** et alertes éditeurs (**Red Hat**, **Ubuntu**, **SUSE**, **VMware**).
La gestion des vulnérabilités	Scan périodique (`Nessus`, `Qualys`, `OpenVAS`), **qualification**, **correction**, **contrôle d'efficacité**.
La gestion des incidents	Détecter (**SIEM** comme `Splunk`), contenir, éradiquer et effectuer un **retour d'expérience** pour améliorer la prévention.
Le plan de reprise/continuité	Assurer la résilience via **RTO** (délai de reprise) et **RPO** (perte de données). Doit être **documenté**, **testé** et **connu**.
L'automatisation	Réduire l'erreur humaine via **Ansible** (configurations), **Terraform** (infrastructure as code), **OpenSCAP**, **Lynis** ou **Wazuh**.

Pièges et confusions

- ⚠ Confondre le contrôle d'accès discrétionnaire (propriétaire décide) avec le contrôle d'accès obligatoire (politique système s'impose même au root).
- ⚠ Associer SELinux à la famille Debian/Ubuntu au lieu de la famille RHEL/Rocky/AlmaLinux.
- ⚠ Associer AppArmor à la famille RHEL/Rocky/AlmaLinux au lieu de la famille Debian/Ubuntu.
- ⚠ Confondre le RTO (délai de reprise de service) avec le RPO (perte de données acceptable).
- ⚠ Oublier de valider une configuration SSH avec sshd -t avant de recharger le service.
- ⚠ Penser que la sécurité d'une infrastructure ne dépend que du système d'exploitation et non de l'ensemble de ses couches.

Sigles et définitions

AQSSI	Autorité Qualifiée pour la Sécurité des Systèmes d'Information, qui porte la responsabilité juridique de la décision.
EBIOS Risk Manager	Méthode française d'analyse des risques numériques développée par l'ANSSI.
PAM	Moteur central de contrôle sous Linux qui applique la politique d'authentification.
SELinux	Mécanisme de contrôle d'accès obligatoire par défaut sur les distributions RHEL, Rocky et AlmaLinux.
SIEM	Plateforme qui centralise et corrèle les journaux de sécurité afin de détecter les incidents.
CVE	Identifiant normalisé attribué à une vulnérabilité connue.
RTO	Délai maximal acceptable pour la reprise d'un service après un incident.

Auto-test

1. Qui signe la décision d'homologation et accepte les risques résiduels ?
2. Quelle méthode française d'analyse des risques utilise 5 ateliers successifs ?
3. Quel outil analyse les journaux pour bannir les IP après des tentatives infructueuses ?
4. Quelle est la règle de sauvegarde pour assurer la résilience ?
5. Quel outil évalue la conformité d'un système selon un profil normalisé ?

Réponses : **1.** L'autorité d'homologation. · **2.** EBIOS Risk Manager. · **3.** Fail2Ban. · **4.** La règle 3 2 1. · **5.** OpenSCAP.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.